



Access control



What is access control

- It is an mechanism that aim to restrict access to resource and place
 - For example:
 - Student are not allow go into staff office
 - Storage space in a shop isn't allow customer to go inside
- In computer or network, we rely on the following method:
 - Authentication: to verify your identity
 - Authorization: to verify your right to carry out actions



Type of access control methodology

- Discretionary access control
 - It refers to rule of access control that is set by or granted the right to access an object by the owner of object
 - ie) you allow your brother to have access to your computer
- Mandatory access control
 - It refers to rule of access control that is set or granted the right to access an object by a centralised authority
 - ie) the company you are currently working grant you access to company's data files



Discretionary access control type

- Discretionary access control
 - The owner grant you the right to access things(object)
- Rule based access control
 - The owner have listed a set of rules and he used them to grant right to access things(object)



Non-discretionary access control type

- The common non-discretionary access control types:
 - Role based access control
 - The authority grant you right to access base on role in organisation
 - Content based access control
 - The authority grant you right to access base on the content of the things(object)
 - Context based access control
 - The authority grant you right to access base on the reason you provide to access information, the right is often temporary and dynamic



Identity and access management

- It is a structural process or system to authenticate and grant people with right to access resources
- After authenticate the identity and grant people with access right, we also concern about the how we manage these information
- There is 4 component in identity and access management:
 - Identification
 - Authentication
 - Authorization
 - Audit log



Identification

- It is stage of the process, the organisation will request personal information to create profile of you
- The profile assert you as a unique user of the system and provide accountability
- Same step can be done on a process, which the system will create a profile for a process and provide accountability for a process



Authentication

- During authentication, the organisation will verify the provided personal information is correct and valid for accountability
- The organisation will verify the provided personal information by contacting related organisation, including past companies, government organisation and ask other third party organisation provide verification services to complete verification process.
- After the initial verification, authentication will be apply for every time, you try to use your identity to access resources.
- These authentication factors are:
 - Something you know: password
 - Something you have: ID card
 - Something you are: facial pattern
- Most organisation will used password as the primary authentication method to authenticate user identity



Authorization

- After authenticating and verification, you will be granted access right base on type of access control strategy the organisation adopted.
- Role based access control and Content based access control is commonly and widely used.
- Access control in an organisation often involved a hierarchy structure and follow the rule of can't look up, can't write down
- The access privilege should always follow the principle of least privilege - meaning only granted the minimal right to allow subject to finish the task



Audit log

- It is used to record and provide accountability for the action that you have carry out.
- It will record your access and change applied to resources.
 - For example: you change a documentation, and the status before and after change will be logged.
- It makes the person become accountable for the changes and supported by evidence with metadata.
- In the event of unauthorised access, the audit log will record the action which allows the investigation and the recovery process can be deliver easily and efficiently.